

ANALISIS DE VULNERABILIDADES

PyPA (Python Packaging Authority)

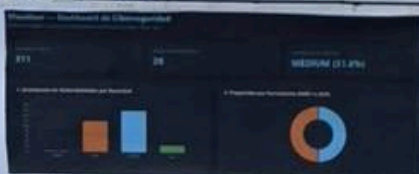
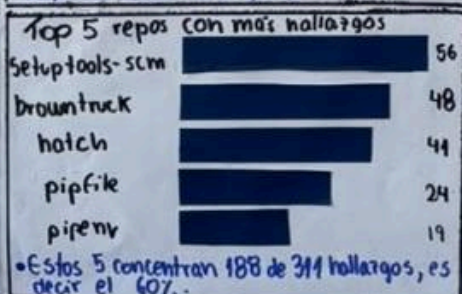
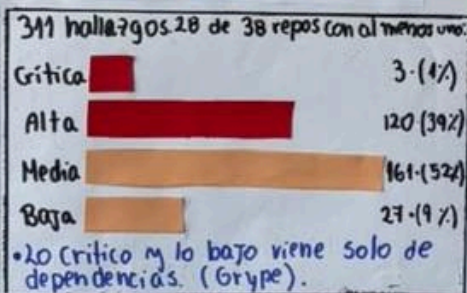
Jonathan Manguel - Bastián Escobar - Fernanda Vega

PROBLEMA

PyPA: mantiene pip, Setuptools y virtualenv
Las herramientas con que se instala casi todo el software Python
Una falla ahí afecta a toda la Cadena de Suministro

Propósito: detectar, analizar y visualizar Vulnerabilidades en 38 de sus 59 repos y auditar con la nuestro Propio Repositorio

RESULTADOS



Profesor:

Pablo Valenzuela



Arquitectura

MINER

Resultados
findings.csv — repos.csv

ANALYZER
• Notebook Jupyter

Visualizer
• HTML con D3.js

- Api de Github
- CodeQL → Código fuente
- Syft → SBOMs
- Grype → Vulnerabilidad de Componentes



CONCLUSIONES

• El código propio de PyPA está bastante limpio: solo 18 de 311 hallazgos están ahí.
El riesgo está en lo que lo rodea: dependencias (156) y CI/CD (78).

• Nuestro Reporter nos dio 6,5/10, el riesgo principal es un posible XSS en el dashboard, por mostrar datos externos con .html() en vez de .text().

• Caímos en lo mismo que PyPA: instalamos herramientas sin verificar y con versiones obsoletas (>=).
La cadena de suministro es el punto débil.